Sicurezza dei Sistemi Informativi

Appello d'Esame del 27 Gennaio 2023

Anno Accademico 2022-2023

Politecnico di Torino — Docente: Prof. Cataldo Basile

2023-01-27

1 Testo Ufficiale dell'Esame

Domanda 1: Analisi Ciphersuite TLS 1.2

Un client e un server del protocollo TLS 1.2 negoziano la seguente ciphersuite:

`TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA256`

a. Spiegare cosa significa ciascuna delle componenti principali della ciphersuite e su quale proprietà di sicurezza (riservatezza, integrità, autenticazione, segretezza in avanti) ha influenza.

b. Spiegare brevemente cosa accade durante il protocollo di Handshake per lo scambio delle chiavi e l'autenticazione del server.

c. Indicare quale è la parte più critica e obsoleta di questa ciphersuite e per quali motivi tecnici e vulnerabilità note (es. Sweet32, problemi di CBC).

Domanda 2: Verifica di Firma Digitale e Certificato X.509

Bob e Alice sono colleghi presso la società SSI Inc. Alice invia a Bob:

- Il suo certificato X.509 a chiave pubblica firmato dalla Certification Authority (CA) aziendale;
- Un file di dati firmato digitalmente con la chiave privata corrispondente alla chiave pubblica presente nel certificato.

Assumendo che la SSI Inc sia dotata di una Public Key Infrastructure (PKI) completa e gestita correttamente sia a livello di registrazione che di infrastruttura, descrivere dettagliatamente tutti i passi che Bob (o un software di verifica al suo posto) deve compiere per stabilire con certezza che la firma sia pienamente valida.

Domanda 3: Privacy by Design e il Ruolo del DPO nel GDPR

Riportare e spiegare 4 aspetti o principi operativi relativi all'implementazione di servizi conformi al principio di **Privacy by Design** secondo il GDPR. Inoltre, spiegare chi è il **Data Protection Officer (DPO)**, quali sono i suoi compiti istituzionali e che tipo di responsabilità giuridica possiede in caso di data breach.

Domanda 4: Autenticazione basata su Password Ripetibili

Spiegare il funzionamento dell'autenticazione basata su password ripetibili (memorizzate e riutilizzabili). Descrivere le principali problematiche di sicurezza che bisogna affrontare:

- Lato client;
- Nel canale di comunicazione;
- Lato server (memorizzazione);
- Problematiche generali e comportamentali degli utenti.

Per ciascuna problematica, indicare le relative misure tecniche di mitigazione (KDF, salting, canali protetti, MFA).

Domanda 5: Meccanismi Anti-SYN Flooding: SYN Interceptor vs SYN Monitor

Indicare quali delle seguenti affermazioni su **SYN Interceptor** e **SYN Monitor** sono vere:

a. Il SYN Interceptor è meno efficace del SYN Monitor;

b. Il SYN Monitor è meno efficace del SYN Interceptor;

c. Non alterano il three-way handshake ma inviano pacchetti al posto del server;

d. Cambiano il three-way handshake per evitare SYN flooding inviando l'hash del sequence number;

e. Il SYN Interceptor risponde al posto del server. Contatta il server stabilendo una connessione solo se il three-way handshake ha successo;

f. Servono entrambi a mitigare gli attacchi di tipo SYN flooding;

g. Il SYN Monitor risponde al posto del server. Contatta il server stabilendo una connessione solo se il three-way handshake ha successo;

h. Nessuno dei due risolve completamente il problema del SYN flooding.

Domanda 6: Progettazione Architettura di Rete e Firewalling

Un'azienda ha una rete suddivisa in tre sottoreti interne:

- Sottorete 1: `192.168.1.0/24` (ospita server interno `192.168.1.1`);
- Sottorete 2: `192.168.2.0/24` (ospita server interno `192.168.2.3`);
- Sottorete 3: `192.168.3.0/24`;
- Server pubblici con indirizzi IP pubblici esposti su Internet.

Politica di sicurezza richiesta:

1. Nessuna restrizione interna ad ognuna delle 3 sottoreti;
2. Il server `192.168.1.1` deve essere raggiungibile dalle sottoreti .2 e .3;

3. Il server `192.168.2.3` deve essere raggiungibile dalla sottorete .1;
4. Nessuna sottorete interna (.1, .2, .3) deve poter essere raggiunta dall'esterno (Internet);
5. Gli host delle sottoreti .1 e .2 possono raggiungere Internet;
6. Gli host della sottorete .3 non possono raggiungere Internet;
7. I server pubblici devono essere raggiungibili da Internet, ma solo su un insieme di URL note (es. `$url1, $url2, ...`).

Indicare quale architettura e quali controlli preventivi abilitare sull'elemento al bordo e riportare le corrispondenti regole di configurazione.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Ciphersuite TLS 1.2

a. Decodifica delle Componenti della Ciphersuite:

- `TLS`: Specifica il protocollo di appartenenza.
- `DHE` (Diffie-Hellman Ephemeral): Meccanismo di scambio delle chiavi. Genera un segreto condiviso effimero garantendo la proprietà di **Perfect Forward Secrecy (PFS)**.
- `RSA`: Algoritmo di crittografia asimmetrica utilizzato dal server esclusivamente per **autenticarsi** presso il client (firmando digitalmente i parametri DH effimeri).
- `3DES_EDE_CBC`: Algoritmo e modalità di cifratura simmetrica per garantire la **confidenzialità** dei dati. Triplo DES con tre fasi (Encrypt-Decrypt-Encrypt) in modalità Cipher Block Chaining.
- `SHA256`: Funzione di hash crittografica a 256 bit utilizzata sia come generatore di MAC (HMAC-SHA256) per garantire **integrità e autenticità** dei pacchetti, sia come base per la Pseudo-Random Function (PRF) per derivare le chiavi.

b. Fasi dell'Handshake per Scambio Chiavi e Autenticazione: Il server genera parametri Diffie-Hellman effimeri casuali $(g, p, g^b \pmod p)$ e li firma digitalmente con la propria chiave privata RSA. Nel messaggio `ServerKeyExchange`, invia tali parametri assieme alla firma e al proprio certificato X.509 (`Certificate`). Il client valida il certificato risalendo alla CA, verifica la firma RSA sui parametri DH usando la chiave pubblica del certificato (autenticazione del server avvenuta). Successivamente, il client genera il proprio valore effimero $g^a \pmod p$, lo invia nel messaggio `ClientKeyExchange`, e calcola il Pre-Master Secret $g^{ab} \pmod p$.

c. Criticità della Ciphersuite: La componente più critica è senza dubbio `3DES_EDE_CBC`:

1. **Vulnerabilità Sweet32 (CVE-2016-2183)**: 3DES utilizza una dimensione di blocco obsoleta di soli **64 bit** (8 byte). A causa del paradosso del compleanno, dopo che una connessione TLS ha cifrato circa $2^{32}/2 = 2^{32}$ blocchi ($\approx$ 32 GB di dati) sotto la stessa chiave, si verifica una collisione nei blocchi di ciphertext con probabilità superiore al 50%. In modalità CBC, ciò consente a un attaccante Man-in-the-Middle (sfruttando codice JavaScript malevolo che induce il browser a generare richieste ripetute) di estrarre cookie HTTP di sessione in chiaro.
2. **Padding Oracle Attack (Vaudenay)**: La combinazione MAC-then-Encrypt con modalità CBC è storicamente affetta da attacchi a canale laterale sui messaggi di errore di padding (Lucky Thirteen, POODLE).
3. **Prestazioni e Chiave Efficace**: 3DES è estremamente lento in software e la sua sicurezza effettiva è di soli 112 bit (invece di 168 bit) a causa degli attacchi meet-in-the-middle. È oggi ufficialmente deprecato dal NIST.

Soluzione Domanda 2: Catena di Verifica del Certificato e della Firma Digitale

Per accertare la validità legale e tecnica del documento e del certificato, Bob deve compiere i seguenti passi sequenziali e rigorosi:

1. **Verifica del Periodo di Validità**: Bob verifica che il timestamp corrente rientri nell'intervallo temporale specificato nei campi `notBefore` e `notAfter` del certificato di Alice.

2. **Costruzione e Verifica della Catena di Fiducia (Trust Chain)**: Bob estrae il nome dell'emittente (`Issuer`) dal certificato di Alice e recupera il certificato della CA aziendale SSI Inc. Verifica che la firma digitale apposta sul certificato di Alice sia valida ricalcolando il digest del certificato e verificandolo con la chiave pubblica della CA. Se la CA aziendale è intermedia, il processo si ripete ricorsivamente fino a raggiungere un certificato radice autofirmato (*Root CA*) presente nel Trust Store locale fidato di Bob.

3. **Verifica dello Stato di Revoca**: Bob deve accertarsi che il certificato di Alice non sia stato revocato prima della sua scadenza naturale (es. per compromissione della chiave privata o cessazione del rapporto lavorativo). Ciò avviene tramite:

   - Download e verifica della **Certificate Revocation List (CRL)** firmata dalla CA;
   - Oppure tramite interrogazione in tempo reale via protocollo **OCSP** (Online Certificate Status Protocol) o verifica del timestamp OCSP Stapling.

4. **Verifica delle Estensioni e del Key Usage**: Bob controlla che l'estensione X.509 `KeyUsage` e/o `ExtendedKeyUsage` autorizzi esplicitamente l'uso della chiave per la firma digitale (*Digital Signature*, *Non-Repudiation*).

5. **Verifica della Firma Digitale sul Documento**:

   (a) Bob calcola autonomamente il digest crittografico $H(M)$ del file ricevuto utilizzando la stessa funzione di hash specificata nell'algoritmo di firma (es. SHA-256).

   (b) Decifra la firma digitale S utilizzando la **chiave pubblica di Alice** estratta dal certificato validato (ad esempio applicando la verifica RSA $S^e \pmod n$ o la formula di verifica ECDSA).

   (c) Confronta il digest ottenuto dalla firma con il digest calcolato $H(M)$. Se coincidono perfettamente, è matematicamente garantita l'**integrità** del file (nessuna modifica post-firma) e l'**autenticità/non ripudio** di Alice.

Soluzione Domanda 3: Privacy by Design e DPO

Principio di Privacy by Design (Art. 25 GDPR): Prevede che la protezione dei dati personali sia integrata fin dalla fase di progettazione e concezione architetturale di qualsiasi sistema, servizio o processo aziendale. I 4 aspetti implementativi fondamentali includono:

1. **Minimizzazione e Pseudonimizzazione**: Il servizio deve trattare e collezionare solo i dati strettamente necessari. Identificativi diretti (es. codice fiscale) devono essere sostituiti con identificativi pseudonimi o token casuali.

2. **Cifratura pervasiva (At Rest e In Transit)**: I dati memorizzati su database/dischi devono essere cifrati (es. AES-256) e le comunicazioni devono essere protette tramite TLS moderno con mutua autenticazione.

3. **Privacy by Default**: Le impostazioni predefinite di sicurezza e riservatezza del servizio devono essere configurate al massimo livello di protezione, senza richiedere azioni correttive all'utente.

4. **Gestione del Ciclo di Vita e Conservazione**: Implementazione di meccanismi automatici di scadenza e cancellazione sicura (*data retention*) al termine del periodo necessario.

Ruolo e Responsabilità del Data Protection Officer (DPO): Il DPO è una figura di garanzia indipendente. I suoi compiti principali sono:

- Consulenza e informazione al Titolare e ai dipendenti sugli obblighi del GDPR;
- Sorveglianza sull'osservanza del Regolamento e delle policy aziendali di sicurezza;
- Cooperazione e punto di contatto con l'Autorità Garante per la Privacy.

Responsabilità legale: Il DPO **non è legalmente responsabile** per eventuali violazioni o data breach dell'azienda e non risponde dei danni agli interessati. La responsabilità civile, penale e amministrativa (sanzioni fino a 20 milioni di euro o al 4% del fatturato annuo globale) ricade esclusivamente sul **Titolare del Trattamento**.

Soluzione Domanda 4: Autenticazione basata su Password Ripetibili

Funzionamento: L'utente presenta un identificativo univoco (username) e un segreto condiviso a priori (password statica memorizzata) per dimostrare la propria identità.
Problematiche e Mitigazioni per Ambito:

Ambito	Vulnerabilità / Minacce	Mitigazioni Tecniche
Lato Client	Keylogger, malware, spyware, shoulder surfing, memorizzazione non sicura nei browser.	Virtual keyboard, isolamento della memoria, password manager con crittografia forte, anti-malware ed EDR.
Canale di Rete	Eavesdropping, packet sniffing, attacchi Man-in-the-Middle e Replay Attack.	Cifratura di canale obbligatoria con TLS 1.3 con certificati verificati (HTTPS), HSTS, protocolli Challenge-Response.
Lato Server	Data breach del database delle credenziali; attacchi a dizionario offline e tabelle precalcolate (Rainbow Tables).	**Mai memorizzare password in chiaro**. Uso di Key Derivation Functions (KDF) memory-hard con sale crittografico (*Salt*) univoco (es. Argon2id, bcrypt, scrypt, PBKDF2) e numero elevato di iterazioni.
Comportamento	Scelta di password banali o corte, riutilizzo della stessa password su più siti (*Credential Stuffing*).	Policy di complessità e lunghezza (minimo 12-16 caratteri), verifica contro elenchi di password compromesse (es. HaveIBeenPwned), **Multi-Factor Authentication (MFA)** obbligatoria (FIDO2/WebAuthn, TOTP).

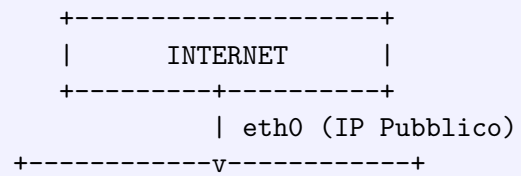
Soluzione Domanda 5: SYN Interceptor vs SYN Monitor

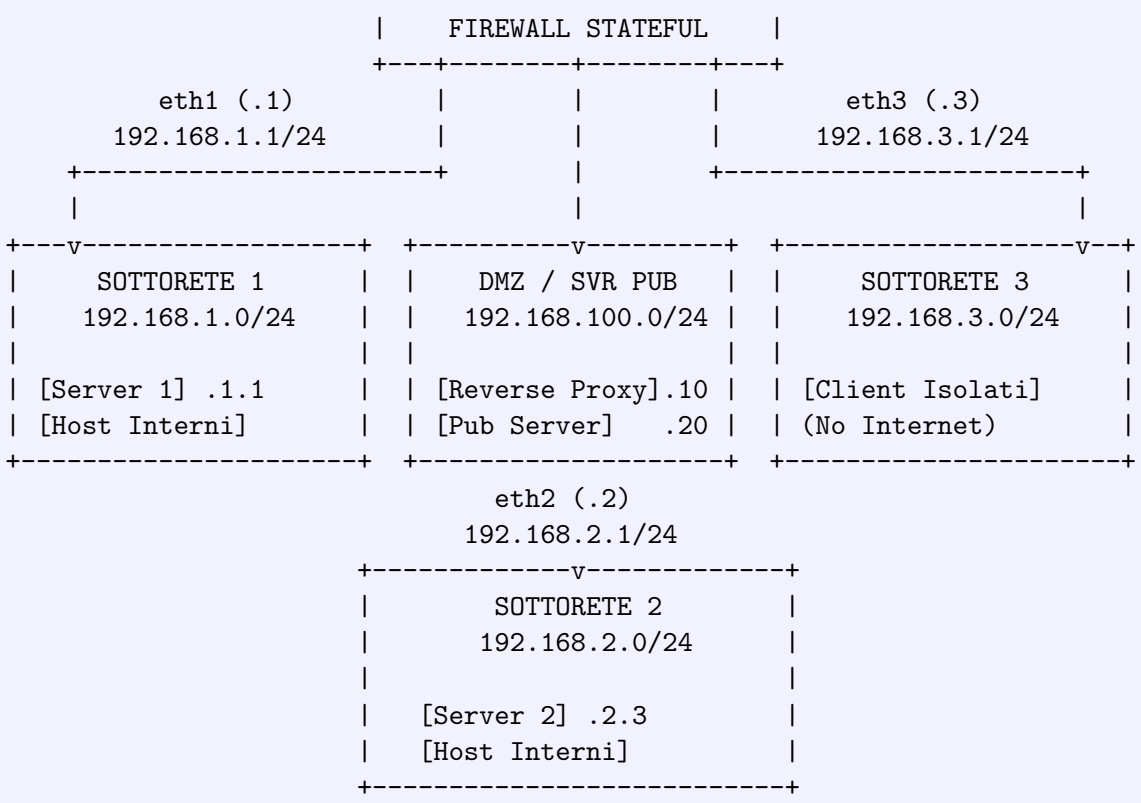
Analisi puntuale ed esaustiva di ciascuna affermazione:

- **a. FALSA**: Il SYN Interceptor è **più efficace** (e non meno efficace) del SYN Monitor poiché intercetta e termina preventivamente il three-way handshake al posto del server, proteggendo la coda delle connessioni semi-aperte (*backlog queue*) del server protetto.
- **b. VERA**: Il SYN Monitor è **meno efficace** del SYN Interceptor perché opera passivamente: non intercetta i pacchetti SYN né risponde al posto del server; osserva solo il traffico e, se nota che una connessione semi-aperta non riceve l'ACK finale entro una soglia temporale, invia un pacchetto `RST` forzato al server per liberare lo slot. Nel frattempo, il server subisce l'occupazione della memoria.
- **c. FALSA**: Entrambi i meccanismi alterano o intervengono attivamente nella gestione del three-way handshake (il SYN Interceptor si sostituisce direttamente al server inviando SYN-ACK al client; il SYN Monitor inietta pacchetti RST postumi).
- **d. FALSA**: La tecnica che modifica la sequenza numerica inviando un hash crittografico nel sequence number iniziale (ISN) è quella dei **SYN Cookies**, un meccanismo interno allo stack TCP dell'OS che non c'entra con apparati di monitoraggio/intercettazione perimetrali.
- **e. VERA**: Il SYN Interceptor opera a tutti gli effetti come un proxy TCP: risponde al SYN del client con un SYN-ACK forgiato; solo dopo che il client ha risposto con l'ACK valido (comprovando che l'indirizzo IP sorgente non è spoofato ed è legittimo), contatta il server backend stabilendo una connessione reale.
- **f. VERA**: Entrambi i sistemi sono stati esplicitamente ideati e standardizzati come contromisure perimetrali contro gli attacchi DoS di tipo TCP SYN Flooding.
- **g. FALSA**: L'affermazione descrive il funzionamento del SYN Interceptor, non del SYN Monitor (il quale non risponde mai al posto del server).
- **h. VERA**: Nessuno dei due risolve completamente e definitivamente il problema: il SYN Monitor lascia il server esposto a sovraccarico momentaneo, mentre il SYN Interceptor sposta su di sé l'intero onere dello stato TCP, diventando esso stesso potenziale bersaglio di DoS/esaurimento risorse di memoria o collo di bottiglia prestazionale.

Soluzione Domanda 6: Architettura di Rete e Tabella Regole Firewall

Architettura Selezionata e Topologia Screened Subnet: Per soddisfare tutti i requisiti, in particolare il filtraggio selettivo sui server pubblici basato su un insieme di URL note (`$url1, $url2, ...`), un packet filter di livello 3/4 non è sufficiente: il router/firewall di bordo deve instradare il traffico HTTP/HTTPS a un **Reverse Proxy L7 (WAF)** posizionato in DMZ.





Subnetting, Instradamento e Logica di Filtraggio:

- **Instradamento Internet**: Le sottoreti .1 e .2 escono su Internet tramite Source NAT (SNAT) su `eth0`. La sottorete .3 è categoricamente bloccata verso Internet.
- **Accesso ai Server Pubblici da Internet**: Il traffico esterno su porte TCP 80/443 è indirizzato esclusivamente al Reverse Proxy in DMZ (`192.168.100.10`), il quale verifica l'URI richiesta: solo se appartiene alla whitelist `$url1, $url2, ...` la richiesta viene inoltrata ai server pubblici (`192.168.100.20`).
- **Traffico Inter-Sottorete**: Regole specifiche autorizzano l'accesso a `192.168.1.1` da .2 e .3, e l'accesso a `192.168.2.3` da .1.

Tabella Regole del Firewall di Bordo (Default Policy: DROP):

ID	Src IP	Dst IP	Proto	Dst Port	State
1	Any	Any	Any	Any	ESTABLISHED, RELAT
2	192.168.1.0/24	192.168.1.0/24	Any	Any	Any
3	192.168.2.0/24	192.168.2.0/24	Any	Any	Any
4	192.168.3.0/24	192.168.3.0/24	Any	Any	Any
5	192.168.2.0/24, 192.168.3.0/24	192.168.1.1	TCP/UDP	Any	NEW
6	192.168.1.0/24	192.168.2.3	TCP/UDP	Any	NEW
7	192.168.1.0/24, 192.168.2.0/24	Any (Internet)	Any	Any	NEW
8	Any (Internet)	Reverse Proxy (DMZ)	TCP	80, 443	NEW
9	Reverse Proxy	Server Pubblici	TCP	80, 443	NEW
10	Any	Any	Any	Any	Any

Alternative Implementation Note: Strutture Rust per un Reverse Proxy con Filtro URL

Se si implementa il proxy inverso di filtraggio URL in Rust:

- `std::sync::Arc<HashSet<String>>`: L'insieme degli URL noti (`$url1, $url2`) viene memorizzato in un `HashSet` protetto da `Arc`, consentendo a centinaia di thread worker Tokio di verificare la validità della richiesta HTTP in tempo medio $O(1)$ senza alcuna contesa di lock.
- `tokio::sync::RwLock`: Qualora la lista delle URL lecite debba essere aggiornata a caldo (senza riavviare il servizio), si utilizza un `RwLock` asincrono per permettere la sostituzione atomica dell'insieme.